HAVELLS BILLING INTELLIGENCE & MIS

Dynamic Role-Based Access Control (RBAC) System Architecture & User Guide

PRODUCTION MANUAL

> **Executive Summary / Overview:**
> Yeh system completely **Database-Driven Dynamic Role-Based Access Control (RBAC)** provide karta hai. Iska sabse bada feature yeh hai ki **Role assign karne se user ki permissions kabhi lock nahi hoti**. Har role ki default permissions hoti hain, aur har user ko bina role badle individual level par **Custom Grant (ALLOW)** ya **Custom Block (DENY)** kiya ja sakta hai — wo bhi bina kisi Python code ko change kiye!

1. 5 Predefined Roles (System Roles)

Database me 5 standard roles create kiye gaye hain jo User creation aur editing ke time dropdown me milte hain:

Role Name	Role Code	Target Users	Permission Behavior
Super Admin	`SUPER_ADMIN`	Directors, System Admins	FULL UNRESTRICTED ACCESS Har dashboard, module, data upload, export, user management aur settings ka complete access. Kisi bhi rule ya override se restrict nahi ho sakta.
Management	`MANAGEMENT`	Top Executives, VPs, HODs	High-level business dashboards (Executive, RM, Monthly, Story, P&L, SPOC). Defaults Django Admin me kabhi bhi badle ja sakte hain.
MIS Executive	`MIS_EXECUTIVE`	Billing Ops, Data Operators	Operational modules (Upload Excel, Import History, Transaction Explorer, Reconciliation, Quality). Upload & Export alag se configured hote hain.
Analyst	`ANALYST`	BI & MIS Analysts	Deep analytics, reports, Story analysis, filters, view & export. Read-only lock nahi hota, admin unhe upload/edit bhi grant kar sakta hai.
Custom User	`CUSTOM_USER`	Special / Guest Users	Default Deny role. Isme koi automatic business access nahi hota. Super Admin jo manually tick karega user ko sirf wahi access milega.

2. 3-State Permission Resolution Model (Kaise Kaam Karta Hai?)

Har user ki effective permissions ko 3-State Model se calculate kiya jata hai:

INHERIT **Role Default (Inheritance)**

ALLOW **Explicit User Grant (Override)**

User apne assigned role ke default rules follow karta hai. Jab Super Admin Role ki permissions modify karta hai, toh jin users ke paas `INHERIT` hai unki permissions **automatically update** ho jati hain.

Chahe role me access **NO** ho, agar user ko `ALLOW` diya gaya hai toh user ko access **mil jayega**. Example: Analyst role me Excel Upload band hai, par Ravi (Analyst) ko Upload par `ALLOW` de diya toh sirf Ravi upload kar payega.

`DENY` Explicit User Block (Override)

Chahe role me access **YES** ho, agar user ko `DENY` set kiya hai toh user ka access **block** ho jayega. Example: Management role me P&L open hai, par Amit ko P&L par `DENY` de diya toh Amit P&L nahi dekh payega.

Priority Order (Decision Flow)

1. Superuser Check: Agar `is_superuser=True` → Unlimited Access.
2. Inactive Check: Agar `is_active=False` → Blocked (403).
3. User Override: `ALLOW` ya `DENY` priority lega.
4. Role Default: Agar `INHERIT` hai toh Role default dekha jayega.

HOW TO USE THE RBAC SYSTEM

Step-by-Step Operator & Administrator Manual

STEP-BY-STEP GUIDE

3. Step-by-Step Usage Scenarios (Ise Kaise Use Karein)

Scenario A: Role ki Default Permissions Change Karna (Django Admin)

Agar aap chahte hain ki kisi Role (e.g. *MIS Executive* ya *Management*) ke saare users ke liye koi module on ya off ho jaye:

1. **Django Admin me jayein:** URL `/admin/` open karke Super Admin se login karein.
2. **Roles section kholein:** Left sidebar ya Core app me **"Roles"** par click karein. Wahan 5 predefined roles dikhenge with assigned user counts.
3. **Permissions Matrix kholein:** Role ke aage blue button **"Permissions Matrix"** par click karein (ya role open karke top-right par matrix button dabayein).
4. **Permissions Tick / Untick karein:** Saare 18 modules across 5 groups display honge with supported actions (View, Add, Edit, Delete, Upload, Export, Manage). Jo allow karna ho tick karein, jo block karna ho untick karein. Toolbars me *"Select All"*, *"Deselect All"*, aur *"View Only"* shortcuts bhi available hain.
5. **Save click karein:** Bottom me **"Save Role Permissions"** dabayein. Yeh instantly database me save ho jayega aur us role ke saare users par lagu ho jayega (jin par user-level override na ho).

Scenario B: Naya User Banakar Role Assign Karna

1. Django Admin me **Authentication and Authorization → Users → Add User** par click karein.
2. Username aur Password enter karke Save and continue editing karein.
3. Neeche **"Profile & RBAC Role"** inline section me **Role dropdown** me se desired role choose karein (e.g. *Analyst*).
4. **Save** karein. User ko turant us role ke saare default permissions mil jayenge!

Scenario C: Kisi Specific User Ko Custom Permissions Dena (Overrides)

Agar kisi user ko unke role se hatkar kuch extra access dena ho ya koi specific cheez block karni ho:

1. Django Admin me **Users** list open karein.
2. User row me dark blue button **"Overrides Matrix"** par click karein.
3. Aapke saamne user ki **Individual Permission Overrides Matrix** open hogi. Har action ke samne 3 options ka dropdown hoga:
   - `INHERIT (Role:YES/NO)` — Role ka default follow karega.
   - `ALLOW (Grant)` — User ko explicitly allow karega (Green color me highlight ho jayega).
   - `DENY (Block)` — User ko explicitly block karega (Red color me highlight ho jayega).
4. **Save Individual Overrides** button dabayein. Changes turant database me save ho jayenge aur us user ke liye apply ho jayenge. Doosre users par koi asar nahi padega!

Scenario D: User ke Overrides Reset Karna (Wapas Role Default Par Lana)

1. User ki **Overrides Matrix** open karein.
2. Top-right me red button **"Reset to Role Defaults"** par click karein aur confirm karein.
3. User ke saare custom overrides delete ho jayenge aur wo 100% apne Role ke default rules par revert ho jayega.

MODULE REGISTRY & ENFORCEMENT

Complete List of Protected Modules & Security Features

SECURITY & MODULES

4. 18 Modules Across 5 Navigation Groups

System me har module database me `AppModule` registry ke roop me register hai:

Group Name	Module Display Name	Module Code	Applicable Actions
1. Overview	Executive Dashboard	`dashboard`	View, Export
2. Data Pipeline	Upload Excel	`upload`	View, Upload
	Import History	`history`	View, Delete, Export
3. Business Analytics	RM Performance	`rm`	View, Export
	Monthly Billing	`monthly`	View, Export
	STORY Analysis	`story`	View, Export
	Payment Reconcile	`payment`	View, Export
	Categories	`category`	View, Export
	Payment SPOC	`spoc`	View, Export
	Dealers & Firms	`dealers`	View, Export
	Profit & Loss (P&L)	`pnl`	View, Export
4. Data Quality & Reports	Data Quality	`quality`	View, Edit, Export
	Category Mapping	`category_mapping`	View, Add, Edit, Delete, Export
	Transaction Explorer	`transactions`	View, Export
	Export & MIS Reports	`export`	View, Export
5. System & Governance	Audit Trail	`audit`	View, Export
	Settings & Definitions	`settings`	View, Edit, Manage
	User & Role Access Control	`rbac`	View, Add, Edit, Delete, Manage

5. Security & Protection Features

Dynamic Sidebar Hiding

User ko sidebar me wahi modules dikhenge jinka unke paas **View Permission** hai. Agar kisi group ke saare modules blocked hain, toh poora group header hi gayab ho jayega.

Strict Backend HTTP 403

Frontend se button chupana sirf convenience hai. Agar user direct browser URL me restricted link type karega, toh server request reject karke **HTTP 403 Forbidden** page render karega.

Action-Level Granular Security

Har sensitive action (Excel Upload, Report Export, Category Mapping Edit, Data Deletion) backend me alag check hota hai. Report dekhne ki permission hone par bhi user report download nahi kar sakta jab tak `can_export` na ho.

High Performance & Audit Logging

Request-level memoized cache use hota hai jisse har sidebar click par database par load nahi padta. Saath hi har Role update aur User override change **Audit Log** me record hota hai.